

Security+ 1.2 · Non-repudiation

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 1.2 — Non-repudiation (7:57)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Não-repúdio: prova irrefutável de QUEM fez — impossível negar depois. Implementação: hash do dado cifrado com a chave PRIVADA de quem assina (assinatura digital). Qualquer um valida com a pública. Base de contrato digital, transação, log de auditoria.

Highlights que a prova cobra

- Hash só prova integridade; assinatura prova integridade + AUTOR
- Assimétrico: privada assina, pública valida
- Prova de não-Repúdio: 'não foi eu' é impossível de alegar após assinado

Dicas de prova & Cenários Típicos

- Se a questão cita 'cannot deny'/'cannot dispute' = non-repudiation
- Qual algoritmo: RSA assinatura (não AES — AES é simétrico, sem autor único)

Cenário clássico de exame: Cenário típico: 'empresa precisa provar ao juiz que o gerente enviou a ordem' → assinatura digital (não-repúdio) com a chave privada do gerente.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 1.2 — Non-repudiation)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **MAC:** Mandatory Access Control: Modelo rígido de controle de acesso governamental/militar baseado em etiquetas de segurança (Top Secret, Secret, Unclassified) atribuídas por autoridade central.
- **WORM:** Write Once, Read Many: Tecnologia de armazenamento imutável que permite gravar dados uma única vez e impede qualquer modificação ou exclusão durante o período de retenção (essencial para logs e conformidade).
- **MFA:** Multi-Factor Authentication: Autenticação multifator exigindo dois ou mais fatores distintos das categorias: algo que você sabe, algo que você tem, algo que você é, algo que você faz ou algum lugar onde você está.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim.
Tente responder antes de olhar.

1. Um executivo sênior alega em juízo que nunca autorizou a transferência de 5 milhões de dólares por e-mail, afirmando que a mensagem foi forjada por terceiros. A equipe forense demonstra que o e-mail foi assinado com a chave privada do executivo vinculada ao seu smart card. Qual propriedade de segurança refuta a alegação do executivo?

- A)** Confidencialidade simétrica
- B)** Não-repúdio (Non-repudiation)
- C)** Disponibilidade com failover
- D)** Hashing SHA-256 isolado

2. Uma empresa de software precisa distribuir atualizações de firmware e garantir que os dispositivos aceitem apenas pacotes legítimos e que a empresa não possa alegar que outra pessoa enviou o firmware. O que deve ser implementado?

- A)** Assinatura digital do binário usando a chave privada da empresa
- B)** Criptografia AES-256 do binário com chave compartilhada
- C)** Cálculo de hash MD5 disponibilizado no site
- D)** Ofuscação de código com compactação ZIP

3. Por que um hash SHA-256 puro (sem chave ou assinatura) NÃO é suficiente para garantir o não-repúdio de um documento?

- A)** Porque o hash é reversível e pode ser descriptografado
- B)** Porque qualquer pessoa pode recalculá-lo de um documento adulterado
- C)** Porque o hash só protege dados em movimento, não em repouso
- D)** Porque o hash exige duas chaves para ser validado

4. Em um esquema de assinatura digital para não-repúdio, qual chave é usada para ASSINAR o resumo criptográfico (digest) e qual é usada pelo destinatário para VALIDAR a assinatura?

- A)** Assina com a chave pública do remetente; valida com a chave privada do remetente
- B)** Assina com a chave privada do destinatário; valida com a chave pública do destinatário
- C)** Assina com a chave privada do remetente; valida com a chave pública do remetente
- D)** Assina com chave simétrica AES compartilhada; valida com a mesma chave

5. Uma organização financeira precisa registrar logs de transações bancárias em conformidade regulatória. Para garantir que nem mesmo os administradores do banco de dados possam alterar ou negar as entradas passadas, qual técnica combinada deve ser utilizada?

- A)** Armazenamento WORM (Write Once, Read Many) assinado digitalmente com carimbo de tempo (timestamping)
- B)** Criptografia reversível com chave armazenada em texto claro
- C)** Backups semanais compactados sem criptografia
- D)** Permissões discricionárias de leitura para todos os usuários

6. Um analista de segurança analisa uma falha de não-repúdio em que um colaborador afirma que outro funcionário usou seu computador para assinar um contrato. Qual controle complementar reforça o não-repúdio do usuário?

- A)** Bloqueio automático de tela e autenticação biométrica/MFA para liberação da chave privada
- B)** Aumento do tamanho do disco rígido
- C)** Troca do cabo Ethernet por Wi-Fi protegido
- D)** Desativação dos logs do sistema operacional

7. Qual elemento da Infraestrutura de Chaves Públicas (PKI) vincula de maneira formal e legal a identidade de uma pessoa à sua chave pública para sustentar o não-repúdio?

- A)** Certificado Digital assinado por uma Autoridade Certificadora (CA)
- B)** Tabela de roteamento do firewall de borda
- C)** Hash MD5 da placa de rede (MAC address)
- D)** Servidor de nomes dinâmico (DDNS)

8. Um contrato digital entre duas empresas foi assinado eletronicamente. Cinco anos depois, uma das partes tenta invalidar o contrato alegando que o algoritmo de hash usado na época era fraco. Qual mecanismo protege a validade jurídica de longo prazo contra essa contestação?

- A)** Carimbo do tempo criptográfico confiável (Time Stamping Authority - TSA) aplicado no momento da assinatura
- B)** Cópia impressa do código-fonte do sistema
- C)** Troca da chave pública por uma chave simétrica secreta
- D)** Reinicialização periódica dos servidores web

9. Se Bob envia uma mensagem criptografada apenas com a chave PÚBLICA de Alice, qual pilar da segurança foi atendido e qual NÃO foi?

- A)** Foi atendida a Confidencialidade; o Não-repúdio do remetente NÃO foi atendido
- B)** Foi atendido o Não-repúdio; a Confidencialidade NÃO foi atendida
- C)** Ambos foram atendidos perfeitamente
- D)** Nenhum objetivo foi atingido

10. Para que Bob consiga enviar uma mensagem a Alice garantindo simultaneamente CONFIDENCIALIDADE e NÃO-REPÚDIO do remetente, qual é o fluxo correto de chaves assimétricas?

- A)** Bob assina a mensagem com sua própria chave privada e cifra o resultado com a chave pública de Alice
- B)** Bob cifra com a chave privada de Alice e assina com a chave pública de Bob
- C)** Bob usa a mesma chave pública tanto para cifrar quanto para assinar
- D)** Alice assina previamente e envia a chave para Bob cifrar

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Não-repúdio (Non-repudiation).

O não-repúdio garante de forma irrefutável a identidade do autor de uma transação através de assinatura digital (chave privada assimétrica), impedindo que ele negue o envio posteriormente.

2) A — Assinatura digital do binário usando a chave privada da empresa.

A assinatura digital provê autenticação de origem, integridade e não-repúdio, pois somente quem possui a chave privada do desenvolvedor pode assinar o pacote.

3) B — Porque qualquer pessoa pode recalcular o hash de um documento adulterado.

O hash garante apenas a integridade matemática (se o dado mudou ou não). Ele não possui identidade vinculada: qualquer pessoa pode alterar o texto e gerar um novo hash correspondente.

4) C — Assina com a chave privada do remetente; valida com a chave pública do remetente.

A assinatura digital é gerada cifrando o hash do documento com a chave PRIVADA do remetente (só ele possui). O destinatário valida a assinatura usando a chave PÚBLICA do remetente.

5) A — Armazenamento WORM (Write Once, Read Many) assinado digitalmente com carimbo de tempo (timestamping).

Mídias WORM impedem modificações posteriores e o carimbo de tempo assinado digitalmente prova quando o evento ocorreu e quem o gerou, garantindo integridade e não-repúdio.

6) A — Bloqueio automático de tela e autenticação biométrica/MFA para liberação da chave privada.

Para que o não-repúdio seja incontestável na prática forense, a chave privada deve estar protegida por fatores de autenticação rigorosos (smart card + PIN/biometria) e bloqueio físico.

7) A — Certificado Digital assinado por uma Autoridade Certificadora (CA).

O Certificado Digital (X.509) emitido por uma CA confiável atesta publicamente a vinculação entre a chave pública e a entidade/indivíduo titular.

8) A — Carimbo do tempo criptográfico confiável (Time Stamping Authority - TSA) aplicado no momento da assinatura.

O carimbo de tempo emitido por uma autoridade confiável (TSA) prova que a assinatura foi criada antes da expiração ou obsolescência do certificado e algoritmos.

9) A — Foi atendida a Confidencialidade; o Não-repúdio do remetente NÃO foi atendido.

Cifrar com a chave pública de Alice garante que apenas Alice pode ler (Confidencialidade). Porém, como a chave pública de Alice é de domínio público, qualquer um poderia ter enviado a mensagem; logo, não há não-repúdio do remetente.

10) A — Bob assina a mensagem com sua própria chave privada e cifra o resultado com a chave pública de Alice.

Assinar com a chave privada de Bob gera não-repúdio/autenticidade. Cifrar com a chave pública de Alice garante confidencialidade exclusiva para Alice.